

Individual or Teamwork of 2		
Student(s) identification		
Last Name	First Name	
Tariq	Muhammad Ibtisam	261265753

6 Points	Title of Incident:	2023 Okta Support Case Management System Data Breach (Okta Help Center / Support System) (Okta, 2023a).	
	Discovery date:	October 19, 2023, when Okta formally notified customers of unauthorized access to its support case management system (Okta, 2023a)	
	Start date of Incident:	September 28, 2023. Okta’s investigation determined that unauthorized access to the support system began on this date (Okta, 2023b).	
	End date of incident:	October 17, 2023. The compromised service account was disabled, and all related sessions were terminated, ending the attacker’s access window (Okta, 2023b)	
	Organization affected:	Okta, Inc., a global provider of cloud-based identity and access management services (Okta, 2023a).	
		Number of employees	Approximately 6,000 employees worldwide as of 2023 (Okta, 2023c).
		Revenues	Approximately USD \$2.26 billion in total revenue for fiscal year 2024 (Okta, 2024)
		Country	United States: headquarters located in San Francisco, California (Okta, 2023c)
		Line of business	Cloud Identity and Access Management (IAM), including workforce and customer identity, single sign on, and multi-factor authentication services (Okta, 2023a)
4	Cause of the incident:	This incident was the result of a deliberate external attack that was made possible by internal security weaknesses. A service account credential had been stored in the support system and was later accessed by a threat actor, allowing unauthorized entry into customer support cases (Okta, 2023).	
	Aspect affected:	The primary security principle affected was confidentiality, as sensitive customer support files and user information were accessed. There was also potential impact to integrity, since exposed session tokens were later used to hijack active user sessions (Okta, 2023)	
10	Incident description		
	Between September 28 and October 17, 2023, an external attacker gained unauthorized access to Okta’s customer support case management system using a compromised service account. During this period, the attacker viewed and downloaded customer support cases and attached files, including HAR files used for troubleshooting. Some of these files contained active session tokens, which allowed the attacker to take over authenticated sessions. The attacker also downloaded a report containing names and email addresses of Okta support system users, increasing the risk of phishing and social engineering attacks (Okta, 2023)		

10	Direct impacts
	The breach exposed sensitive troubleshooting data and authentication artifacts belonging to Okta customers. Okta confirmed that session hijacking occurred in a small number of customer environments, requiring affected organizations to reset credentials, review logs, and strengthen administrative security controls. Additionally, the exposure of support user contact information increased the likelihood of targeted phishing attempts, placing further strain on customer security teams and damaging trust in Okta's support processes (Okta, 2023)
5	Direct cost
	Okta did not publicly disclose the total financial cost of the incident. However, direct costs likely included expenses related to forensic investigations, internal incident response efforts, security engineering remediation, increased customer support workload, and reputational harm resulting from the breach (Okta, 2023)
10	Incident timeline
	September 28, 2023: Unauthorized access to the support system begins. Late September to mid-October 2023: Customers report suspicious activity to Okta support. October 17, 2023: Okta disables the compromised service account and revokes related sessions. October 19, 2023: Okta notifies customers of the incident. November 2023: Okta publishes additional findings and expanded impact disclosures (Okta, 2023)
5	Perpetrator
	The attack was carried out by an external threat actor. Okta did not publicly identify or attribute the activity to a specific hacking group. While forensic evidence confirmed unauthorized access, attribution confidence remains moderate due to limited publicly available details (Okta, 2023)
5	Motivation
	The attacker's likely motivation was to gain unauthorized access to customer environments by exploiting stolen session tokens, enabling follow-on compromise. The collection of user contact information also suggests preparation for phishing or social engineering campaigns. This assessment is based on observed attacker behavior, though no explicit motive was confirmed (Okta, 2023)
10	Vulnerabilities being exploited and techniques used by the attackers
	Several weaknesses contributed to this incident, including improper storage of service account credentials, use of personal cloud profiles on managed devices, and gaps in logging related to file access within the support system. The attacker exploited these vulnerabilities to access support cases, download sensitive files, generate reports, and reuse session tokens to hijack authenticated sessions (Okta, 2023)
10	Incident resolution
	To resolve the incident, Okta disabled the compromised service account, terminated all associated sessions, and revoked exposed session tokens. The company also strengthened monitoring and logging, restricted the use of personal cloud profiles on managed devices, and implemented additional protections for administrative sessions. While these actions addressed the immediate threat, any data accessed by the attacker cannot be fully recovered (Okta, 2023).
5	Communications to external parties
	Okta communicated with customers through a series of security advisories as the investigation progressed. Although the company eventually provided detailed and transparent updates, the gradual expansion of the incident's scope created uncertainty for customers and made response planning more difficult, which impacted trust (Okta, 2023).
10	Long-term impacts

	The incident is expected to have long-term impacts on Okta's reputation as a trusted identity provider. Customers may apply increased scrutiny to Okta's security controls, and the exposed contact information creates an ongoing phishing risk. The breach also reinforces higher security expectations for vendor operated support systems across the industry (Okta, 2023)
10	Lessons learned
	This incident highlights the importance of strict credential management, strong endpoint security policies, comprehensive logging, and least privilege access in support environments. While Okta's response was thorough, the breach suggests that stronger preventive controls and oversight could have reduced the likelihood or impact of the incident (Okta, 2023).

REFERENCES

Okta. (2023). Security incident advisory: Okta support case management system. <https://www.okta.com>

Okta. (2023). Root cause analysis of Okta support system incident. <https://www.okta.coM>

Okta. (2023). Okta annual report. <https://www.okta.com>

Okta. (2024). Okta Form 10-K annual report. <https://www.okta.coM>